



TRIBUNAL DE CONTAS DO ESTADO DO RIO DE JANEIRO
SECRETARIA-GERAL DE CONTROLE EXTERNO – SGE
SUBSECRETARIA DE CONTROLE DE POLÍTICAS DE CIDADANIA
COORDENADORIA DE AUDITORIA EM POLÍTICAS DE TECNOLOGIA DA INFORMAÇÃO

COMENTÁRIOS DO GESTOR

DETRAN - Departamento de Trânsito do Estado do Rio de Janeiro

1. Introdução

Este documento orienta a manifestação da **DETRAN** na fase de comentários do gestor. Conforme o caso, a manifestação poderá tratar dos achados e situações de inadequação registrados no Relatório Individual Preliminar, dos itens avaliados como não conformes na etapa de avaliação das evidências ou da ausência de resposta válida ao questionário iGovTI 2026.

A manifestação deve ser apresentada no questionário eletrônico de comentários do gestor, observando-se apenas as seções disponibilizadas para a organização.

Quando houver achados, a organização deverá informar se concorda ou discorda de cada situação apontada e, quando couber, apresentar comentários, justificativas e documentação comprobatória. Nas questões-base indicadas na seção de reavaliação de evidências, a organização poderá apresentar esclarecimentos, retificações ou evidência suplementar para reanálise dos itens avaliados como não conformes. Quando não houver resposta válida ao questionário iGovTI 2026, a manifestação deverá se limitar a esclarecimentos, comprovação de eventual envio anterior ou justificativa para a ausência de resposta.

A etapa de comentários do gestor é desejável, mas tem caráter opcional para a organização auditada. Sua finalidade é permitir que o gestor apresente esclarecimentos sobre fatos, retifique informações, informe providências adotadas ou planejadas e encaminhe documentação complementar pertinente.

Considerando a natureza da solicitação, relativa aos comentários dos gestores sobre achados de auditoria, o prazo para finalização e envio do questionário é **improrrogável**, conforme o item 8.4 do Manual de Auditoria do TCE-RJ, e se encerra em **10/07/2026**.

Recomenda-se que o questionário seja preenchido com antecedência. Eventuais solicitações de esclarecimento poderão ser encaminhadas para o e-mail **auditoriati@tcerj.tc.br**.

Achado 2 – Governança de TIC insuficiente para avaliar, dirigir e monitorar a tecnologia da informação.

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **DETRAN** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação **“Modelo básico de governança e gestão de TIC inexistente ou insuficiente quanto a papéis, responsabilidades, objetivos, indicadores, metas ou acompanhamento.”** apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “Comitê de TIC ou instância equivalente não instituído formalmente.”
apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação **“Comitê de TIC ou instância equivalente sem evidências suficientes de atuação efetiva.”** apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP

Achado 3 – Planejamento de TIC insuficiente para orientar a gestão, o orçamento e as contratações de TIC

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **DETRAN** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação **“Inexistência ou fragilidade do processo formal de planejamento de TIC.”** apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “Ausência de aprovação formal do plano de TIC.” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação **“Plano de TIC sem alinhamento adequado ao planejamento institucional.”** apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “**Plano de TIC sem vínculo demonstrado com orçamento e contratações de TIC**” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “Ausência de acompanhamento, revisão ou atualização periódica do plano de TIC.” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP

Achado 4 – Capacidade institucional insuficiente para sustentar a gestão de TIC e segurança da informação

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **DETRAN** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação “Ausência de força de trabalho dedicada à TIC ou à segurança da informação.” apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação **“A organização não definiu o quantitativo necessário de pessoal de TIC e segurança da informação.”** apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “**Perfis profissionais de TIC e segurança da informação inexistentes, insuficientes ou não utilizados na escolha de gestores.**” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “**Lacunas de competências dos colaboradores e gestores de TIC e segurança da informação não são identificadas ou tratadas.**” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP

Achado 5 – Gestão de serviços de TIC insuficiente para assegurar controle sobre serviços, ativos e incidentes

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **DETRAN** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação “**Inexistência ou insuficiência do catálogo de serviços de TIC.**” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “Ausência ou fragilidade na definição e no monitoramento de níveis mínimos de serviço de TIC.” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “**Inexistência ou fragilidade do inventário de ativos de TIC.**” apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “**Ausência ou fragilidade do processo de gestão de configuração.**” apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação **“Inexistência ou fragilidade do processo de gestão de incidentes de TIC.”** apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP

Achado 6 – Fragilidades na governança técnica da fase preparatória das contratações de TIC

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **DETRAN** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação **“Inexistência ou fragilidade de processo formal e padronizado para contratações de TIC.”** apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “**Contratações de TIC sem análise prévia e aprovação técnica obrigatória da área de TIC.**” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “Contratações de TIC sem alinhamento demonstrado ao planejamento de TIC, ao plano de contratações ou à proposta orçamentária.” apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



Reavaliação de evidências

Esta seção permite que a organização apresente comentários, esclarecimentos, retificações ou evidência suplementar para reavaliação de questões que tiveram pelo menos um item ou subitem classificado como não conforme na etapa de avaliação das evidências.

Consulte no Relatório Individual Preliminar e nos anexos correspondentes os itens específicos avaliados como não conformes. A apresentação de nova evidência é opcional e deve se limitar a arquivo em formato PDF ou ZIP.

Questão 0103. A organização definiu formalmente as atribuições e competências da área de tecnologia da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q0103 - b) a área de TI possui atribuições formalizadas relacionadas ao desenvolvimento, manutenção ou integração de sistemas
Resposta informada pelo auditado	Sim
Avaliação	A evidência apresentada descreve papéis de liderança e gestão da segurança da informação, contudo, carece de dispositivos que detalhem as competências técnicas específicas da área de tecnologia para o desenvolvimento, manutenção e integração de sistemas. A ausência de detalhamento dessas atribuições operacionais em TI constitui uma lacuna documental.
Item avaliado	Q0103 - f) a área de TI possui atribuições formalizadas relacionadas à gestão de dados, análise de dados, automação ou inteligência artificial
Resposta informada pelo auditado	Sim
Avaliação	Embora a política estabeleça diretrizes sobre a proteção de dados pessoais, ela não define as competências da área de tecnologia quanto à gestão analítica de dados, automação ou inteligência artificial. A carência de normatização para tais funções é um limitante identificado na evidência.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 1001. A alta administração estabeleceu modelo de gestão de tecnologia da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q1001 - A alta administração estabeleceu modelo de gestão de tecnologia da informação.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A evidência apresentada consiste estritamente em uma Política de Segurança da Informação e Comunicação (POSIC), a qual não supre a necessidade de um modelo abrangente de gestão de tecnologia da informação. Não foram apresentados documentos que comprovem o planejamento estratégico de tecnologia, a gestão corporativa de riscos tecnológicos, a definição de indicadores de desempenho ou a existência de estruturas de governança institucional. A documentação fornecida apresenta lacunas críticas ao restringir-se ao escopo de segurança da informação.
Item avaliado	Q1001 - a) a organização define as diretrizes para o planejamento de tecnologia da informação
Resposta informada pelo auditado	Sim
Avaliação	A Portaria apresentada aborda diretrizes de segurança da informação, não compreendendo o planejamento estratégico ou tático de tecnologia da informação. Não consta na evidência qualquer normativo que estabeleça diretrizes de planejamento para a área de tecnologia.
Item avaliado	Q1001 - b) a organização define as diretrizes para gestão de riscos de tecnologia da informação
Resposta informada pelo auditado	Sim
Avaliação	A Política apresentada limita-se a diretrizes de segurança da informação e proteção de dados, não abarcando a gestão de riscos de tecnologia da informação em âmbito corporativo conforme requerido. Não foram localizados elementos que comprovem diretrizes para riscos de TI além dos de segurança.
Item avaliado	Q1001 - c) a organização define os papéis e responsabilidades da área de gestão de tecnologia da informação
Resposta informada pelo auditado	Sim
Avaliação	O documento define papéis e responsabilidades restritos à segurança da informação e privacidade, como os previstos nos artigos 13 a 16 da POSIC. Não há evidência que descreva a estrutura de responsabilidades da área de tecnologia da informação em sua totalidade.



Item avaliado	Q1001 - d) a organização designa responsáveis de cada área de negócio para a gestão dos respectivos sistemas informatizados
Resposta informada pelo auditado	Sim
Avaliação	Não há evidências ou menções na documentação fornecida sobre a designação formal de responsáveis das áreas de negócio para a gestão de sistemas informatizados. O documento foca exclusivamente em atribuições de segurança.
Item avaliado	Q1001 - e) a organização dispõe de comitê de tecnologia da informação composto por representantes de áreas relevantes da organização
Resposta informada pelo auditado	Sim
Avaliação	A documentação apresentada não faz qualquer menção à existência ou composição de um comitê de tecnologia da informação. Não foi possível verificar a conformidade deste ponto.
Item avaliado	Q1001 - f) o comitê de tecnologia da informação realiza as atividades previstas em ato constitutivo
Resposta informada pelo auditado	Sim
Avaliação	Dada a inexistência de comprovação documental sobre a constituição ou existência de um comitê de tecnologia da informação, não é possível validar o exercício de suas atividades.
Item avaliado	Q1001 - g) a organização define as diretrizes para avaliação do desempenho dos serviços de tecnologia da informação
Resposta informada pelo auditado	Sim
Avaliação	A evidência fornecida restringe-se a diretrizes de segurança, não contemplando a definição de critérios, indicadores ou diretrizes para a avaliação de desempenho dos serviços de TI em geral.
Item avaliado	Q1001 - h) a organização estabeleceu objetivos, indicadores e metas para a gestão de tecnologia da informação
Resposta informada pelo auditado	Sim
Avaliação	Não constam no documento apresentado objetivos, indicadores ou metas para a gestão de TI. A POSIC trata apenas de diretrizes de segurança, sendo insuficiente para atender a este quesito.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

--



TRIBUNAL DE CONTAS DO ESTADO DO RIO DE JANEIRO
SECRETARIA-GERAL DE CONTROLE EXTERNO – SGE
SUBSECRETARIA DE CONTROLE DE POLÍTICAS DE CIDADANIA
COORDENADORIA DE AUDITORIA EM POLÍTICAS DE TECNOLOGIA DA INFORMAÇÃO

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 1002. A alta administração monitora o desempenho da gestão de tecnologia da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q1002 - A alta administração monitora o desempenho da gestão de tecnologia da informação.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A evidência apresentada consiste apenas na Política de Segurança da Informação e Comunicação (POSIC), a qual define diretrizes, normas e responsabilidades institucionais voltadas à segurança e proteção de dados. O documento não apresenta mecanismos, rotinas, indicadores de desempenho, painéis de gestão ou relatórios que comprovem o monitoramento estratégico ou operacional do desempenho da gestão de tecnologia da informação pela alta administração. A lacuna reside na ausência de registros documentais que demonstrem a medição e o acompanhamento sistemático de metas, projetos ou níveis de serviço de TI.
Item avaliado	Q1002 - a) rotinas de monitoramento do desempenho da gestão de tecnologia da informação estão definidas
Resposta informada pelo auditado	Sim
Avaliação	A POSIC estabelece diretrizes para a segurança da informação, mas não define rotinas, periodicidade ou processos voltados ao monitoramento do desempenho da gestão de tecnologia da informação. A documentação fornecida é insuficiente para atender ao requisito de existência de rotinas de medição de performance da área de TI.
Item avaliado	Q1002 - b) há acompanhamento na execução dos planos vigentes quanto ao alcance das metas estabelecidas
Resposta informada pelo auditado	Sim
Avaliação	O documento enviado não contém evidências de planos de TI, metas estabelecidas ou registros que demonstrem o acompanhamento de sua execução. A evidência carece de elementos que liguem a política de segurança à gestão de planos e metas de tecnologia.
Item avaliado	Q1002 - c) os indicadores de desempenho da gestão de tecnologia da informação estão implantados (há coleta e análise dos dados necessários à medição de desempenho)
Resposta informada pelo auditado	Sim
Avaliação	Não foram apresentadas evidências da implantação de indicadores de desempenho (KPIs) voltados à gestão de TI. Não constam documentos que demonstrem a existência de processos para a coleta e análise de dados de performance da área.



Item avaliado	Q1002 - d) relatórios de medição de desempenho da gestão de tecnologia da informação estão disponíveis à liderança
Resposta informada pelo auditado	Sim
Avaliação	A evidência fornecida não contempla relatórios de medição de desempenho direcionados à liderança ou à alta administração. Inexistem registros ou instâncias documentadas de disponibilização de informações sobre performance de TI.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 1004. A organização definiu metas para a simplificação do atendimento prestado aos usuários dos serviços públicos.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q1004 - A organização definiu metas para a simplificação do atendimento prestado aos usuários dos serviços públicos.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A evidência apresentada é insuficiente para sustentar a adoção das metas de simplificação do atendimento. O conjunto documental enviado consiste exclusivamente em relatórios técnicos de monitoramento de performance e disponibilidade de sistemas de TI. Não foram apresentados planos, estratégias, atas ou documentos de governança que estabeleçam metas formais de simplificação para o atendimento ao usuário.
Item avaliado	Q1004 - a) há metas para a ampliação da oferta de serviços públicos prestados em meio digital
Resposta informada pelo auditado	Sim
Avaliação	Os relatórios de monitoramento de sistemas técnicos não contêm elementos que comprovem a existência de metas para a digitalização de serviços. A evidência é limitada a métricas de infraestrutura, sem qualquer registro de planejamento para ampliação da oferta digital.
Item avaliado	Q1004 - b) há metas com vistas à eliminação da exigência de atestados, certidões ou outros documentos comprobatórios que constem em base de dados oficial da administração pública federal, como condição para a prestação de serviços
Resposta informada pelo auditado	Sim
Avaliação	A documentação técnica enviada restringe-se ao controle de disponibilidade de sistemas, não constando qualquer meta de simplificação documental ou integração de bases de dados. Não há evidências que sustentem a existência de metas para a eliminação de exigências documentais.
Item avaliado	Q1004 - c) há metas para reduzir a necessidade de atendimento presencial dos usuários em todas as etapas de prestação dos serviços públicos (p. ex.: por meio da automação completa das etapas de: solicitação, acompanhamento de solicitações, execução de procedimentos e comunicação de resultados)
Resposta informada pelo auditado	Sim

Avaliação	Não há evidências nos relatórios técnicos de monitoramento sobre metas de redução de atendimento presencial ou planos de automação de etapas dos serviços públicos. O documento enviado limita-se a métricas operacionais de infraestrutura.	
Item avaliado	Q1004 - d) há metas voltadas à melhoria e ao incremento da atuação integrada e sistêmica com outros órgãos e entidades dos quais dependa ou com os quais interaja intensivamente na prestação dos serviços públicos, tais como metas de compartilhamento de dados e metas de interoperabilidade relacionadas à adoção de procedimentos, ferramentas e plataformas comuns (p. ex.: Plataforma de Cidadania Digital)	
Resposta informada pelo auditado	Sim	
Avaliação	Os relatórios de TI apresentados não comprovam a existência de metas de interoperabilidade ou integração sistêmica com outros órgãos. A evidência técnica não permite aferir qualquer planejamento de atuação integrada.	
Item avaliado	Q1004 - e) há metas com vistas a otimizar o uso de múltiplos canais de atendimento (p. ex.: canal presencial, telefone, canal digital/internet, aplicativos móveis, correio eletrônico etc.), de modo a assegurar que canal adequado esteja disponível para usuários com necessidades especiais e, no caso de serviços críticos e relevantes, que canais alternativos estejam disponíveis, se falhar o canal principal	
Resposta informada pelo auditado	Sim	
Avaliação	A evidência fornecida é composta apenas por dados de performance de sistemas, sendo insuficiente para demonstrar a existência de metas de otimização de múltiplos canais de atendimento. Não há registro de estratégias para atendimento inclusivo ou redundância de canais.	
Item avaliado	Q1004 - f) a organização utiliza a gestão de riscos como instrumento para promover a simplificação de procedimentos associados à prestação de serviços públicos, de modo a assegurar que somente sejam utilizados os controles indispensáveis, de acordo com os limites de exposição a riscos institucionalmente definidos, e que sejam eliminados controles desnecessários ou economicamente desvantajosos	
Resposta informada pelo auditado	Sim	
Avaliação	Os relatórios de monitoramento de sistemas enviados não comprovam a aplicação da gestão de riscos para promover a simplificação de procedimentos administrativos. Não foram apresentadas evidências sobre a revisão de controles desnecessários com base em avaliação de riscos.	

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.



TRIBUNAL DE CONTAS DO ESTADO DO RIO DE JANEIRO
SECRETARIA-GERAL DE CONTROLE EXTERNO – SGE
SUBSECRETARIA DE CONTROLE DE POLÍTICAS DE CIDADANIA
COORDENADORIA DE AUDITORIA EM POLÍTICAS DE TECNOLOGIA DA INFORMAÇÃO

Apenas um arquivo PDF ou ZIP

Questão 2101. A organização executa processo de planejamento de tecnologia da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2101 - A organização executa processo de planejamento de tecnologia da informação.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A avaliação realizada indica que o processo de planejamento de TI não está implementado no órgão. Os documentos apresentados referem-se a designações de pessoal para áreas diversas, como LGPD e segurança da informação, e a normas de contratação externas ao planejamento estratégico de tecnologia. A evidência é insuficiente para atestar a existência de planejamento de TI, dada a ausência de planos vigentes (PDTI/PETIC) ou registros institucionais correlatos.
Item avaliado	Q2101 - a) as áreas demandantes de soluções de TI participam do processo de planejamento de tecnologia da informação
Resposta informada pelo auditado	Sim
Avaliação	A avaliação realizada indica que não há comprovação da participação de áreas demandantes no planejamento de TI. Não foram apresentados registros, atas ou normativos que evidenciassem tal envolvimento nas ações de tecnologia da informação. A evidência é insuficiente, dada a ausência total de documentação que relacione demandas de áreas internas com o planejamento de tecnologia.
Item avaliado	Q2101 - b) a organização estabeleceu critérios para orientar a seleção e a priorização das iniciativas de TI (projetos e ações) e os mantém atualizados
Resposta informada pelo auditado	Sim
Avaliação	A avaliação realizada indica que a organização não estabeleceu critérios formais de seleção e priorização de iniciativas de TI. O pacote probatório não contém matrizes, rankings, catálogos de priorização ou instrumentos análogos que orientem decisões de TI. A evidência é insuficiente por omitir a formalização de critérios técnicos ou gerenciais para a priorização de investimentos em tecnologia.
Item avaliado	Q2101 - c) as análises de benefícios, de custos e de riscos subsidiam as decisões relacionadas à seleção e à priorização das iniciativas de TI (projetos e ações)
Resposta informada pelo auditado	Sim
Avaliação	A avaliação realizada indica a inexistência de análises de benefícios, custos ou riscos para subsidiar decisões de TI. Não constam estudos de viabilidade, business cases ou análises multicritério referentes a projetos de tecnologia da informação. A evidência é insuficiente



devido à ausência de documentos técnicos que fundamentem a seleção ou priorização de iniciativas de TI.

Item avaliado Q2101 - d) o processo de planejamento de TI está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)

Resposta informada pelo Sim

auditado

Avaliação A avaliação realizada indica que o processo de planejamento de TI não está formalizado. Não foi apresentado normativo interno, guia ou portaria que discipline a execução do planejamento, a definição de responsabilidades e as orientações para o processo de TI no âmbito da organização. A evidência é insuficiente pela total ausência de instrumento formal que regulamente a governança e o planejamento de TI.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2201. A organização elabora um catálogo de serviços de tecnologia da informação e monitora níveis de serviço.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2201 - A organização elabora um catálogo de serviços de tecnologia da informação e monitora níveis de serviço.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A evidência apresentada é um Termo de Referência prospectivo para contratação de serviços, que não constitui um catálogo de serviços vigente e operacionalizado, nem demonstra a efetiva monitoração contínua de níveis de serviço pela organização.
Item avaliado	Q2201 - a) o catálogo contém as metas definidas para cada serviço (p. ex.: prazos de entrega, horários de serviço e de suporte, bem como pontos de contato para solicitação do serviço, envio de sugestões, esclarecimento de dúvidas e reporte de incidentes)
Resposta informada pelo auditado	Sim
Avaliação	O documento não apresenta um catálogo estruturado com metas de serviço acessível a usuários, contendo apenas disposições contratuais sobre prazos de execução para a futura empresa contratada.
Item avaliado	Q2201 - b) o catálogo está atualizado e as informações que nele constam são compatíveis com os Acordos de Níveis de Serviço (ANS) estabelecidos pela área de tecnologia da informação e as áreas de negócio da organização
Resposta informada pelo auditado	Sim
Avaliação	Não foram apresentados Acordos de Nível de Serviço (ANS) firmados entre a TI e as áreas de negócio do DETRAN/RJ, nem evidências de catálogo atualizado que possua compatibilidade verificável com tais acordos.
Item avaliado	Q2201 - c) o catálogo é de fácil acesso e está amplamente disponível a seus usuários e às equipes de suporte
Resposta informada pelo auditado	Sim
Avaliação	Não há evidências de publicação ou disponibilização do catálogo para usuários e equipes de suporte, uma vez que o documento base é apenas uma instrução licitatória interna.
Item avaliado	Q2201 - d) são formalizados ANS contendo metas de nível de serviço acordadas com representantes das áreas de negócio clientes



Resposta

informada pelo Sim

auditado

Avaliação Os indicadores de desempenho presentes no documento são metas contratuais entre o DETRAN/RJ e a contratada, não configurando ANS formalizados com as áreas de negócio internas da organização.

Item avaliado Q2201 - e) a área de gestão de tecnologia da informação monitora continuamente o alcance dos níveis de serviço estabelecidos nos ANS

Resposta

informada pelo Sim

auditado

Avaliação O documento prevê apenas a obrigatoriedade da futura contratada de emitir relatórios de desempenho, sem que haja demonstração ou evidência de que a TI monitore continuamente tais níveis ou ANS com áreas de negócio.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2202. A organização executa processo de gestão de mudanças.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2202 - A organização executa processo de gestão de mudanças.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A evidência apresentada consiste apenas na Política de Segurança da Informação e Comunicação (POSIC), que não estabelece ou detalha um processo de gestão de mudanças de tecnologia. Faltam elementos institucionais, tais como fluxos, responsabilidades, procedimentos de testes e comitês de mudança (CAB) necessários para formalizar a execução deste processo. A evidência é insuficiente para sustentar a afirmação de que a organização executa o processo de gestão de mudanças.
Item avaliado	Q2202 - a) a organização estabeleceu critérios para orientar a aprovação de mudanças, inclusive quanto ao tratamento de casos de exceção (mudanças emergenciais)
Resposta informada pelo auditado	Sim
Avaliação	A política enviada não define critérios técnicos ou operacionais para a aprovação de mudanças, nem estabelece tratamento diferenciado para situações emergenciais. Não há documento complementar que contemple esses requisitos específicos de gestão de mudanças.
Item avaliado	Q2202 - b) mudanças são previamente comunicadas a todas as partes que possam ser afetadas
Resposta informada pelo auditado	Sim
Avaliação	Não consta na documentação apresentada qualquer procedimento que exija ou oriente a comunicação prévia de mudanças de TI às partes interessadas. A evidência limita-se a diretrizes gerais de segurança e não aborda processos de comunicação de mudanças.
Item avaliado	Q2202 - c) identificam-se os serviços e ativos de TI que possam ser afetados pela mudança, de modo a avaliar impactos em níveis de serviços acordados
Resposta informada pelo auditado	Sim
Avaliação	O documento apresentado estabelece princípios gerais de gestão de ativos, contudo, é omissa quanto à identificação de dependências e análise de impacto decorrentes de mudanças em serviços ou níveis de serviço de TI.
Item avaliado	Q2202 - d) a realização de cada mudança é precedida de planejamento e testes



Resposta
informada pelo Sim
auditado
Avaliação

A política de segurança não estabelece a obrigatoriedade de planejamento e testes prévios à execução de alterações no ambiente tecnológico. Não foram fornecidos documentos ou normas operacionais que detalhem essas fases essenciais da gestão de mudanças.

Item avaliado Q2202 - e) mudanças executadas são rastreáveis e monitoradas, com vistas à avaliação de sua efetividade e para permitir ações corretivas, no caso de ocorrência de efeitos não identificados nas fases de planejamento e testes

Resposta
informada pelo Sim
auditado
Avaliação

A documentação fornecida não descreve mecanismos de rastreabilidade ou monitoramento pós-implementação de mudanças. Não há elementos que comprovem a capacidade de avaliação de efetividade ou adoção de ações corretivas em mudanças executadas.

Item avaliado Q2202 - f) o processo de gestão de mudanças está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)

Resposta
informada pelo Sim
auditado
Avaliação

A Portaria apresentada institui uma política de segurança da informação, que se caracteriza por diretrizes de alto nível e não como norma técnica de gestão de mudanças de TI. Falta um documento específico que formalize o fluxo, as atribuições e as diretrizes detalhadas para a gestão de mudanças.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2203. A organização executa processo de gestão de configuração e ativos (de serviços de tecnologia da informação).

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2203 - A organização executa processo de gestão de configuração e ativos (de serviços de tecnologia da informação).
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A evidência apresentada é insuficiente para comprovar a execução do processo de gestão de configuração e ativos de TI. O relatório de atividades de janeiro de 2026, presente nas páginas 1 e 2 do documento '00089_11_2203-relatorio-atividades-periodo-de-01.01.2026-a-31.01.2026.pdf', descreve apenas tarefas operacionais rotineiras, como monitoramento de bancos de dados e backups. Não foi apresentado documento normativo ou registro que demonstre a estruturação desse processo. A lacuna consiste na ausência de evidência que comprove o estabelecimento e a execução sistemática de gestão de configuração e ativos.
Item avaliado	Q2203 - a) a organização mantém uma base de dados consolidada e atualizada com as configurações dos serviços e ativos de TI e o relacionamento entre eles
Resposta informada pelo auditado	Sim
Avaliação	Não há comprovação da manutenção de uma base de dados consolidada de configurações. Embora o relatório mencione ativos técnicos, não apresenta qualquer evidência de uma CMDB ou registro de relacionamentos entre serviços e ativos, conforme exposto nas páginas 1 e 2 do documento encaminhado. Falta a apresentação do instrumento ou base que consolide essas informações de forma estruturada.
Item avaliado	Q2203 - b) a base de dados de configurações é utilizada como insumo para o planejamento e o acompanhamento das mudanças
Resposta informada pelo auditado	Sim
Avaliação	A evidência enviada é insuficiente para demonstrar a vinculação entre uma base de dados de configuração e o processo de mudanças. Embora o relatório liste alterações em sistemas e webservices, na página 1, não há menção ou comprovação de que uma base de configuração foi utilizada como insumo para essas ações. Identifica-se a lacuna de um processo documentado que relacione a base de ativos ao gerenciamento de mudanças.
Item avaliado	Q2203 - c) o processo de gestão de configuração e ativos está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)



Resposta

informada pelo Sim

auditado

Avaliação

O documento encaminhado, um relatório de atividades operacionais, não supre o requisito de formalização do processo. Não foram enviados normativos, políticas ou guias que estabeleçam diretrizes e responsabilidades para a gestão de configuração e ativos. Existe a lacuna quanto à ausência de qualquer documento institucional ou ato normativo que fundamente o referido processo.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2204. A organização executa processo(s) de gestão de incidentes de serviços de tecnologia da informação e de incidentes de segurança da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2204 - A organização executa processo(s) de gestão de incidentes de serviços de tecnologia da informação e de incidentes de segurança da informação.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A evidência apresentada consiste em relatório operacional de chamados de TI, o qual é insuficiente para comprovar a gestão de incidentes de segurança da informação. Embora existam dados sobre o atendimento de serviços de TI, não foram apresentados documentos que demonstrem a abrangência do processo conforme exigido pelo critério. A ausência de evidências de gestão de incidentes de segurança da informação constitui lacuna crítica.
Item avaliado	Q2204 - a) a organização definiu regras para a priorização e o escalamento de incidentes
Resposta informada pelo auditado	Sim
Avaliação	O documento apresentado registra apenas resultados operacionais, não contendo as regras, matrizes ou diretrizes formais que fundamentem a priorização e o escalonamento. A inexistência de norma ou documento descritivo sobre o fluxo de tratamento impede a verificação deste item. O relatório enviado não supre a necessidade de apresentação da regra institucional de priorização.
Item avaliado	Q2204 - c) há base(s) de conhecimento que registra(m) erros conhecidos e problemas, de modo a tornar eficiente e efetiva a resolução de incidentes
Resposta informada pelo auditado	Sim
Avaliação	O relatório apresentado é um documento de apuração de indicadores e não contém informações ou links para repositórios de erros conhecidos. Não há indicação da existência de uma base de conhecimento para suporte à gestão de incidentes. A falta de evidência sobre este repositório torna o item não conforme.
Item avaliado	Q2204 - d) o(s) processo(s) de gestão de incidentes está(ão) formalizado(s) (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)
Resposta informada pelo auditado	Sim
Avaliação	A evidência limita-se a um relatório de desempenho contratual, sem valor normativo ou descritivo da formalização do processo de gestão. O item exige norma interna ou



instrumento equivalente de formalização e responsabilidades, que não foi disponibilizado. A ausência de documento normativo instituidor do processo constitui a lacuna principal.

Item avaliado Q2204 - e) a organização definiu procedimentos e responsabilidades quanto à notificação e ao tratamento das notificações de incidentes de segurança da informação, bem como quanto à adoção de ações emergenciais, diretrizes para escalamento e comunicação interna e externa

Resposta informada pelo auditado Sim

Avaliação Não há qualquer evidência que aborde incidentes de segurança da informação no documento apresentado. O relatório restringe-se a atividades operacionais de suporte de TI, sem tratar de protocolos de segurança ou ações emergenciais específicas. A ausência total de procedimentos relacionados à segurança da informação torna o item não conforme.

Item avaliado Q2204 - f) a organização definiu procedimentos e responsabilidades quanto à análise dos incidentes, identificação de causas raízes e planejamento e implementação de ações corretivas

Resposta informada pelo auditado Sim

Avaliação O relatório apresenta apenas justificativas contextuais para atrasos operacionais, sem demonstrar metodologia formal de análise de causa raiz. Não há evidência de plano de ações corretivas ou definição de responsabilidades para análise estruturada de incidentes. A ausência de documento que formalize o procedimento de análise de causa raiz inviabiliza a conformidade.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2301. A organização executa processo de gestão dos riscos de tecnologia da informação relativos a processos de negócio.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2301 - A organização executa processo de gestão dos riscos de tecnologia da informação relativos a processos de negócio.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	O processo de gestão de riscos de Tecnologia da Informação não foi comprovado. A evidência enviada, o 'Plano de Resposta a Incidentes de Segurança com Dados Pessoais', trata exclusivamente de ações reativas a incidentes já confirmados ou sob suspeita, conforme detalhado nas páginas 23 a 33, não contemplando as etapas de identificação, avaliação ou tratamento preventivo de riscos de TI nos processos de negócio. A evidência é insuficiente por tratar de um escopo distinto do solicitado.
Item avaliado	Q2301 - a) a organização identifica e avalia os riscos associados com o uso de Tecnologia da Informação nos processos organizacionais críticos para o negócio (Riscos de TI)
Resposta informada pelo auditado	Sim
Avaliação	A evidência apresentada descreve o fluxo de resposta a incidentes de segurança, conforme páginas 23 a 31, e não demonstra o processo de identificação e avaliação proativa de riscos de TI nos processos organizacionais. Não há evidências de registros ou instrumentos que identifiquem os riscos associados ao uso de TI.
Item avaliado	Q2301 - b) a organização trata os Riscos de TI com base em um plano de tratamento de risco
Resposta informada pelo auditado	Sim
Avaliação	A documentação fornecida refere-se a um plano de resposta a incidentes, conforme páginas 23 a 31, que possui finalidade diversa de um plano de tratamento de riscos. Não há evidência da existência de um plano de tratamento para riscos de TI.
Item avaliado	Q2301 - c) o processo de gestão dos riscos de tecnologia da informação está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)
Resposta informada pelo auditado	Sim
Avaliação	O documento apresentado formaliza um processo de resposta a incidentes, não um processo de gestão de riscos de TI. O conteúdo não estabelece normas ou orientações para



a execução da gestão de riscos de TI, sendo o escopo da documentação restrito à proteção de dados e resposta a eventos adversos.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2302. A organização executa processo de gestão de riscos de segurança da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2302 - A organização executa processo de gestão de riscos de segurança da informação.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A organização instituiu normativo que define diretrizes e responsabilidades para a gestão de riscos, conforme evidenciado pela POSIC (Portaria 6739/2025). Contudo, a evidência é insuficiente por não apresentar registros, inventários de risco ou relatórios que demonstrem a execução prática dessas atividades. Persiste a lacuna quanto à comprovação da aplicação efetiva do processo de gestão de riscos de segurança da informação.
Item avaliado	Q2302 - a) a organização identifica e avalia riscos de segurança da informação
Resposta informada pelo auditado	Sim
Avaliação	Embora a POSIC estabeleça a diretriz de mapeamento de ameaças e vulnerabilidades, não foram apresentadas evidências documentais de que a identificação e avaliação de riscos estejam sendo efetivamente realizadas. A evidência carece de registros que demonstrem a prática da atividade descrita no normativo.
Item avaliado	Q2302 - b) a organização trata riscos de segurança da informação com base em um plano de tratamento de riscos
Resposta informada pelo auditado	Sim
Avaliação	Não foram fornecidos documentos que comprovem a existência ou a execução de planos de tratamento de riscos para os ativos de informação da organização. A ausência de planos documentados ou registros de mitigação impede a verificação desta prática.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP



TRIBUNAL DE CONTAS DO ESTADO DO RIO DE JANEIRO
SECRETARIA-GERAL DE CONTROLE EXTERNO – SGE
SUBSECRETARIA DE CONTROLE DE POLÍTICAS DE CIDADANIA
COORDENADORIA DE AUDITORIA EM POLÍTICAS DE TECNOLOGIA DA INFORMAÇÃO

Questão 2303. A organização executa processo de gestão de continuidade de serviços de tecnologia da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2303 - A organização executa processo de gestão de continuidade de serviços de tecnologia da informação.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A evidência fornecida não demonstra a existência de um processo estruturado de gestão de continuidade. O relatório de atividades de TI lista apenas tarefas operacionais rotineiras de manutenção, backup e monitoramento. A ausência de um documento formal de gestão de continuidade torna a evidência insuficiente para sustentar a afirmação.
Item avaliado	Q2303 - a) a organização elabora um plano de continuidade de serviços de TI
Resposta informada pelo auditado	Sim
Avaliação	Não foi apresentado o Plano de Continuidade de Serviços de TI. A documentação fornecida restringe-se a um relatório de atividades operacionais mensais, que não supre a necessidade de evidenciar o plano de continuidade.
Item avaliado	Q2303 - b) as ações e os prazos definidos no plano de continuidade de serviços de TI fundamentam-se em análises de impacto no negócio (AIN/BIA) realizadas sobre os processos organizacionais críticos
Resposta informada pelo auditado	Sim
Avaliação	Não há evidências de realização de análises de impacto no negócio (AIN/BIA). A inexistência de um plano formal impede a verificação da base de fundamentação exigida pela norma.
Item avaliado	Q2303 - c) o plano de continuidade de serviços de TI é testado e revisado periodicamente
Resposta informada pelo auditado	Sim
Avaliação	Não foram apresentados registros de testes ou revisões periódicas do plano de continuidade. As atividades técnicas citadas são de caráter rotineiro e não se confundem com o ciclo de testes e revisões de um plano de gestão de continuidade.
Item avaliado	Q2303 - d) o processo de gestão de continuidade de serviços de TI está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)



Resposta

informada pelo Sim

auditado

Avaliação

Não foi apresentada norma interna, política ou guia que formalize o processo de gestão de continuidade. O relatório de atividades não contém orientações processuais nem definição de responsabilidades conforme exigido.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2403. A organização possui um gestor institucional de segurança da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2403 - b) o gestor institucional de segurança da informação reporta-se diretamente à alta administração
Resposta informada pelo auditado	Sim
Avaliação	A documentação fornecida é insuficiente para demonstrar o nível hierárquico do cargo ou a existência de linha de reporte direto à alta administração. Não foram apresentados organogramas ou atos regimentais que fundamentem a afirmação.
Item avaliado	Q2403 - c) o gestor institucional de segurança da informação coordena o processo de gestão de riscos de segurança da informação em âmbito institucional
Resposta informada pelo auditado	Sim
Avaliação	Embora o documento mencione a designação do gestor, não há descrição detalhada ou comprovação de que ele coordena o processo de gestão de riscos de segurança da informação na instituição.
Item avaliado	Q2403 - e) o gestor institucional de segurança da informação fomenta e coordena ações periódicas de conscientização e de treinamento em segurança da informação para todas as partes interessadas, incluindo autoridades, servidores e colaboradores
Resposta informada pelo auditado	Sim
Avaliação	Não constam na evidência apresentada informações que comprovem a atuação do gestor na coordenação ou fomento de programas de conscientização e treinamento em segurança da informação.
Item avaliado	Q2403 - f) o gestor institucional de segurança da informação detém as prerrogativas e os recursos necessários para o desempenho de todas as suas competências
Resposta informada pelo auditado	Sim
Avaliação	Não foram fornecidos documentos ou registros que comprovem a alocação de recursos ou a concessão de prerrogativas específicas ao gestor para o exercício de suas atribuições.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

--



TRIBUNAL DE CONTAS DO ESTADO DO RIO DE JANEIRO
SECRETARIA-GERAL DE CONTROLE EXTERNO – SGE
SUBSECRETARIA DE CONTROLE DE POLÍTICAS DE CIDADANIA
COORDENADORIA DE AUDITORIA EM POLÍTICAS DE TECNOLOGIA DA INFORMAÇÃO

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP



Questão 2501. A organização executa processo de gestão de ativos associados à informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2501 - e) o processo de gestão de ativos associados à informação subsidia a implantação de ações mitigatórias aplicáveis no caso de ocorrência de evento catastrófico que inviabilize a utilização de ativos
Resposta informada pelo auditado	Sim
Avaliação	A evidência apresentada, a POSIC, trata genericamente da realização de backups, mas não contém dispositivos que operacionalizem o processo de gestão de ativos como suporte a ações mitigatórias específicas para eventos catastróficos que inviabilizem o uso dos ativos. Falta um Plano de Continuidade de Negócios (PCN) ou Plano de Recuperação de Desastres (PRD) que conecte a gestão de ativos a tais cenários críticos.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2502. A organização executa processo de controle de acesso à informação e aos ativos associados à informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2502 - b) os controles de acesso implementados na organização aplicam o princípio “necessidade de conhecer”, o qual prescreve que deve haver necessidade legítima que justifique o acesso à informação por pessoa, sistema ou entidade, bem como o princípio “privilegio mínimo”, o qual estabelece que o perfil de acesso concedido deve incluir tão somente os poderes necessários para o atendimento das legítimas necessidades
Resposta informada pelo auditado	Sim
Avaliação	Não foram apresentadas evidências documentais que comprovem a aplicação formal dos princípios de necessidade de conhecer e privilégio mínimo. O relatório de atividades enviado restringe-se a descrever tarefas técnicas operacionais sem demonstrar os critérios de concessão de acessos. A ausência de matrizes de permissão ou registros de solicitações justificadas impossibilita a verificação deste requisito.
Item avaliado	Q2502 - c) há controles de acesso lógicos na organização que utilizam autenticação com certificado digital ICP-Brasil, a fim de prover identificação inequívoca de pessoas físicas e jurídicas e comprovação de autoria em transações digitais
Resposta informada pelo auditado	Sim
Avaliação	O relatório de atividades fornecido não faz menção à utilização de certificados digitais padrão ICP-Brasil em nenhum dos ambientes citados. Não há evidência técnica ou normativa que comprove a adoção desse mecanismo de autenticação para as transações ou acessos descritos. É necessário apresentar documentação técnica que detalhe a configuração ou o uso da ICP-Brasil no controle de acesso.
Item avaliado	Q2502 - d) a organização analisa criticamente, a intervalos regulares, os direitos de acesso lógicos e físicos existentes, com vistas à remoção de direitos que deixaram de ser necessários e para assegurar que privilégios indevidos não foram obtidos
Resposta informada pelo auditado	Sim
Avaliação	Não foram fornecidos registros, atas ou cronogramas que comprovem a realização de auditorias ou revisões periódicas dos direitos de acesso. O documento analisado limita-se a reportar demandas operacionais de inclusão de usuários e tarefas cotidianas. Falta evidência de que os acessos vigentes passam por análise crítica de necessidade e conformidade em intervalos regulares.
Item avaliado	Q2502 - e) a organização instituiu uma Política de Controle de Acesso (PCA), a qual estabelece princípios, objetivos, diretrizes, principais atividades e responsabilidades relativos ao processo de controle de acesso



Resposta

informada pelo Sim

auditado

Avaliação

O documento encaminhado constitui um relatório mensal de atividades operacionais, não se confundindo com o instrumento normativo denominado Política de Controle de Acesso. A inexistência de um documento formal que estabeleça princípios, diretrizes e responsabilidades inviabiliza a verificação deste item. É necessária a apresentação da norma institucional de controle de acesso aprovada.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2503. A organização executa processo para classificação e tratamento de informações.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2503 - A organização executa processo para classificação e tratamento de informações.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	O documento apresentado, intitulado 'Plano de Resposta a Incidentes de Segurança com Dados Pessoais', não constitui um processo abrangente de classificação e tratamento de informações conforme exigido. A evidência limita-se a fluxos de resposta a incidentes cibernéticos e não estabelece critérios de classificação (como sigilo ou sensibilidade) ou rotulagem para os ativos de informação da organização em geral.
Item avaliado	Q2503 - a) informações pessoais são identificadas e rotuladas, com vistas a viabilizar adequado tratamento e proteção
Resposta informada pelo auditado	Sim
Avaliação	Embora o documento trate de dados pessoais no contexto de incidentes de segurança, não há previsão de um processo formalizado para a identificação e rotulagem contínua desses dados, o que é necessário para assegurar o tratamento e a proteção adequados conforme o item.
Item avaliado	Q2503 - b) a organização informa em seu sítio eletrônico as hipóteses em que, no exercício de suas competências, realiza o tratamento de dados pessoais, bem como fornece informações claras e atualizadas sobre a previsão legal, a finalidade, os procedimentos e as práticas de tratamento que utiliza
Resposta informada pelo auditado	Sim
Avaliação	Não foi apresentada evidência comprobatória da disponibilização das informações obrigatórias no sítio eletrônico do órgão. O plano de resposta a incidentes fornecido não supre a falta de transparência ativa exigida pelo item.
Item avaliado	Q2503 - c) informações sigilosas em razão de sua imprescindibilidade à segurança da sociedade ou do Estado são identificadas e rotuladas, com vistas a viabilizar adequado tratamento e proteção
Resposta informada pelo auditado	Sim
Avaliação	Não foram apresentadas evidências ou normas que estabeleçam a identificação e a rotulagem de informações sigilosas relacionadas à segurança da sociedade ou do Estado. O escopo da evidência enviada é restrito a dados pessoais.



Item avaliado	Q2503 - d) informações sigilosas em função de outras hipóteses legais de sigilo ou segredo são identificadas e rotuladas, com vistas a viabilizar adequado tratamento e proteção
Resposta informada pelo auditado	Sim
Avaliação	O documento encaminhado não contempla procedimentos de identificação ou rotulagem para informações amparadas por outras hipóteses legais de sigilo, limitando-se estritamente à governança de dados pessoais em caso de incidentes.
Item avaliado	Q2503 - e) informações críticas para a organização em razão de necessidades do negócio (p. ex. requisitos associados à integridade, disponibilidade, autenticidade ou a outros atributos da informação) são identificadas e rotuladas, com vistas a viabilizar adequado tratamento e proteção
Resposta informada pelo auditado	Sim
Avaliação	Embora o glossário mencione 'ativo de informação crítico', não foi demonstrada a existência de um processo formalizado de identificação e rotulagem dessas informações para o negócio. A análise limita-se à categorização técnica de incidentes.
Item avaliado	Q2503 - f) o processo de classificação e tratamento de informações está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)
Resposta informada pelo auditado	Sim
Avaliação	A evidência apresentada é um 'Plano de Resposta a Incidentes' e não uma norma ou guia de classificação e tratamento de informações. Não há, no instrumento apresentado, orientações abrangentes sobre a execução do processo de classificação e rotulagem dos ativos da organização.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP



Questão 2504. A organização executa atividades de gestão da segurança dos recursos de processamento da informação, inclusive dos recursos de computação em nuvem.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2504 - j) a organização implementa cópias regulares de segurança (backup) das informações em meio digital, conforme as melhores práticas e as necessidades de negócio, incluindo a realização periódica de testes de recuperação das informações
Resposta informada pelo auditado	Sim
Avaliação	Apesar de citar 'Políticas de backup robustas' no mapa de riscos como medida de mitigação, o Termo de Referência refere-se apenas a serviços de monitoramento de segurança cibernética e testes de intrusão, não havendo evidência concreta da execução de backups e de testes de recuperação de informações em operação.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2505. A organização realiza periodicamente ações de treinamento e/ou capacitação em segurança da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2505 - A organização realiza periodicamente ações de treinamento e/ou capacitação em segurança da informação.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A evidência apresentada, composta pela Política de Segurança da Informação e Comunicação (POSIC), estabelece apenas diretrizes normativas e responsabilidades organizacionais sobre o tema. Não foram fornecidos registros, relatórios, certificados ou cronogramas que comprovem a efetiva realização, implementação e periodicidade de tais ações de treinamento ou capacitação. A ausência de elementos comprobatórios da execução prática torna a evidência insuficiente para sustentar a conformidade alegada.
Item avaliado	Q2505 - a) a organização realiza ações de capacitação voltadas para segurança da informação
Resposta informada pelo auditado	Sim
Avaliação	Embora o normativo institucional preveja a realização de capacitação, não há documentação comprobatória da execução dessas ações. A evidência limita-se à previsão legal, carecendo de registros que confirmem a efetividade das ações de capacitação mencionadas.
Item avaliado	Q2505 - b) a organização participa de ações de capacitação voltadas para segurança da informação
Resposta informada pelo auditado	Sim
Avaliação	O documento institucional define a obrigatoriedade da participação dos colaboradores em cursos, mas não apresenta evidências da participação efetiva por parte do quadro de pessoal. Não há registros, certificados ou relatórios que comprovem que a organização e seus colaboradores tenham participado de tais ações.
Item avaliado	Q2505 - c) a organização realiza ações de conscientização em segurança de TIC
Resposta informada pelo auditado	Sim
Avaliação	A normativa estabelece a responsabilidade de implementar medidas de conscientização, porém não foram fornecidos elementos que comprovem a realização concreta dessas atividades. Falta a comprovação documental de campanhas, materiais educativos ou comunicações internas realizadas.



Item avaliado	Q2505 - d) a organização possui programa permanente de conscientização em segurança da informação
Resposta informada pelo auditado	Sim
Avaliação	A evidência apresentada resume-se ao arcabouço normativo que institui a Política de Segurança, não demonstrando a existência ou a operacionalização de um programa permanente de conscientização. A ausência de evidências da execução prática impede a confirmação do item.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2601. A organização executa um processo de software.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2601 - A organização executa um processo de software.
Resposta informada pelo auditado	Adota parcialmente.
Avaliação	A documentação apresentada refere-se exclusivamente à Política de Segurança da Informação e Comunicação, não evidenciando a existência de um processo de engenharia de software. Não foram fornecidos manuais, guias ou normas técnicas que descrevam o ciclo de vida, metodologias de desenvolvimento ou a gestão operacional de softwares.
Item avaliado	Q2601 - a) o processo de software utilizado pela organização promove a participação de representante da área de negócio como integrante da equipe de desenvolvimento ou aquisição de software, desde sua concepção até a aceitação final
Resposta informada pelo auditado	Sim
Avaliação	A evidência apresentada não aborda os fluxos de desenvolvimento ou aquisição de software. Não é possível constatar a participação formal de representantes da área de negócio em ciclos de vida de software.
Item avaliado	Q2601 - b) o processo de software da organização promove a identificação precoce de requisitos de segurança da informação e a gestão permanente desses requisitos durante todo o ciclo de vida do software
Resposta informada pelo auditado	Sim
Avaliação	Embora a política mencione a proteção da informação em contratações, não há descrição de um processo de software que integre requisitos de segurança ao longo do ciclo de vida. O documento foca em diretrizes gerais de segurança e não em metodologias de engenharia de software.
Item avaliado	Q2601 - c) o processo de software da organização promove a identificação precoce de requisitos de acessibilidade e de usabilidade, bem como a gestão permanente desses requisitos durante todo o ciclo de vida do software
Resposta informada pelo auditado	Sim
Avaliação	A evidência fornecida não contém orientações, normas ou registros sobre a identificação e o acompanhamento de requisitos de acessibilidade e usabilidade em sistemas.
Item avaliado	Q2601 - d) a organização assegura os seus direitos autorais, de propriedade e de uso relativamente ao software que desenvolve por meio de contratação



Resposta
informada pelo Sim

auditado

Avaliação Não constam na documentação diretrizes ou cláusulas contratuais específicas sobre a titularidade de direitos autorais e de propriedade intelectual de softwares contratados ou desenvolvidos.

Item avaliado Q2601 - e) organização avalia, por meio de mensurações, indicadores e metas, a qualidade do software desenvolvido ou adquirido

Resposta
informada pelo Sim

auditado

Avaliação A evidência enviada é insuficiente, pois trata apenas de diretrizes de segurança. Não há registros de indicadores, metas ou processos de medição de qualidade de software.

Item avaliado Q2601 - f) o processo de software está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)

Resposta
informada pelo Sim

auditado

Avaliação A Portaria apresentada refere-se à governança de segurança da informação e não supre a necessidade de formalização de um processo de engenharia de software.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP



Questão 2602. A organização executa processo de gestão de projetos de tecnologia da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2602 - c) é realizada a gestão de riscos de cada um dos projetos de alta materialidade ou alta relevância
Resposta informada pelo auditado	Sim
Avaliação	A evidência enviada limita-se a demonstrar o acompanhamento operacional e cronogramas, não contemplando registros, matrizes ou planos de gestão de riscos. A suficiência da evidência é insuficiente por não apresentar elementos sobre a atividade de gestão de riscos. Falta a comprovação de instrumentos ou registros de controle específicos para riscos em projetos de alta relevância.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2701. Os perfis profissionais desejados para cada ocupação ou grupo de ocupações de gestão de tecnologia da informação estão definidos e documentados.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2701 - Os perfis profissionais desejados para cada ocupação ou grupo de ocupações de gestão de tecnologia da informação estão definidos e documentados.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A evidência apresentada, a Política de Segurança da Informação e Comunicação (POSIC), define papéis e atribuições operacionais, mas não apresenta o perfil profissional desejado para as ocupações de gestão de TI. Falta a descrição detalhada de competências, habilidades, qualificações e requisitos exigidos para esses cargos. A evidência é insuficiente por não conter elementos que caracterizem o perfil profissional solicitado.
Item avaliado	Q2701 - c) relacionou-se, no perfil profissional, além de requerimentos de ordem legal, um conjunto de competências e habilidades que os ocupantes dos cargos de gestão devem possuir
Resposta informada pelo auditado	Sim
Avaliação	A documentação apresentada limita-se a elencar atribuições funcionais e responsabilidades relativas à segurança da informação, não relacionando competências técnicas, gerenciais ou habilidades específicas para os ocupantes dos cargos. A evidência é insuficiente por não apresentar o detalhamento do perfil profissional exigido pelo requisito.
Item avaliado	Q2701 - d) a organização utiliza mecanismos de transparência ativa para disponibilizar às partes interessadas internas e externas os perfis profissionais definidos para as ocupações de gestão
Resposta informada pelo auditado	Sim
Avaliação	Embora a POSIC seja um documento público, não foram apresentados perfis profissionais definidos contendo competências e habilidades, nem evidências de que tais perfis tenham sido disponibilizados via mecanismos de transparência ativa. O elemento faltante é a comprovação da existência e da publicidade ativa de perfis profissionais de gestão de TI.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

--



TRIBUNAL DE CONTAS DO ESTADO DO RIO DE JANEIRO
SECRETARIA-GERAL DE CONTROLE EXTERNO – SGE
SUBSECRETARIA DE CONTROLE DE POLÍTICAS DE CIDADANIA
COORDENADORIA DE AUDITORIA EM POLÍTICAS DE TECNOLOGIA DA INFORMAÇÃO

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2705. As lacunas de competências dos colaboradores e gestores da área de tecnologia da informação e de segurança da informação são identificadas e documentadas.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2705 - As lacunas de competências dos colaboradores e gestores da área de tecnologia da informação e de segurança da informação são identificadas e documentadas.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A Política de Segurança da Informação (POSIC) apresentada estabelece diretrizes e responsabilidades institucionais, mas não constitui prova da efetiva execução do processo de identificação e documentação de lacunas. Não foram apresentados registros, diagnósticos, matrizes de competências ou planos de capacitação que comprovem a identificação de lacunas para os públicos descritos. Faltam evidências operacionais que demonstrem a aplicação prática das responsabilidades previstas na norma.
Item avaliado	Q2705 - a) as lacunas de competências pessoais (transversais, comuns a todos os colaboradores) da organização são identificadas e documentadas
Resposta informada pelo auditado	Sim
Avaliação	A evidência restringe-se a instituir normas e diretrizes de segurança, sem contemplar registros que identifiquem lacunas de competências pessoais transversais. Não foram fornecidos diagnósticos, levantamentos ou relatórios que comprovem a existência de um processo de identificação destas competências. Faltam elementos documentais específicos que comprovem a análise de gaps transversais.
Item avaliado	Q2705 - b) as lacunas de competências de liderança e gestão necessárias para a atuação dos gestores da organização são identificadas e documentadas
Resposta informada pelo auditado	Sim
Avaliação	A documentação apresentada não contém registros, relatórios ou matrizes de competências gerenciais que comprovem a identificação de lacunas de liderança. A POSIC define responsabilidades, mas não detalha ou evidencia a avaliação das competências necessárias aos gestores. Faltam documentos que evidenciem o diagnóstico de necessidades de desenvolvimento para este público.
Item avaliado	Q2705 - c) as lacunas de competências técnicas da área de tecnologia da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas
Resposta informada pelo auditado	Sim



Avaliação	Não foram apresentados elementos que demonstrem a identificação de lacunas técnicas em tecnologia da informação. A norma estabelece papéis institucionais, mas carece de diagnósticos, planos de desenvolvimento ou matrizes técnicas que comprovem a avaliação das competências dos colaboradores da área. Faltam registros documentais de identificação de gaps técnicos.	
Item avaliado	Q2705 - d) as lacunas de competências técnicas da área de segurança da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas	
Resposta informada pelo auditado	Sim	
Avaliação	A evidência apresentada não contempla o diagnóstico ou a documentação de lacunas técnicas específicas da área de segurança da informação. Embora a política preveja conscientização, não foram apresentados registros ou matrizes de competências que identifiquem falhas ou necessidades de aprimoramento técnico. Faltam documentos comprobatórios do processo de identificação de lacunas técnicas em segurança.	

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2706. As lacunas de competências dos colaboradores e gestores da área de tecnologia da informação e de segurança da informação da organização são tratadas.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2706 - As lacunas de competências dos colaboradores e gestores da área de tecnologia da informação e de segurança da informação da organização são tratadas.
Resposta informada pelo auditado	Adota parcialmente.
Avaliação	A evidência apresentada (POSIC) estabelece apenas a obrigatoriedade de um curso de conscientização genérico para todos os colaboradores, sem contemplar o tratamento de lacunas de competências técnicas específicas para a área de tecnologia e segurança da informação. A documentação normativa é insuficiente, pois não demonstra o diagnóstico das necessidades de treinamento nem a execução de planos estruturados para o público-alvo da questão. Inexiste evidência sobre a identificação ou o tratamento direcionado de lacunas de competências técnicas.
Item avaliado	Q2706 - b) a organização incentiva seus colaboradores e gestores a participar das ações de capacitação existentes
Resposta informada pelo auditado	Sim
Avaliação	A política apresentada aborda apenas o incentivo à conscientização sobre as normas internas de segurança, não configurando incentivo à participação em programas de capacitação técnica profissional. Não foram apresentadas evidências de mecanismos, programas ou campanhas de incentivo ao desenvolvimento de competências específicas para os colaboradores e gestores das áreas de TI e segurança.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2707. A organização realiza, formalmente, avaliação de desempenho individual do pessoal de tecnologia da informação e de segurança da informação, com atribuição de nota ou conceito, tendo como critério de avaliação o alcance das metas previstas.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2707 - A organização realiza, formalmente, avaliação de desempenho individual do pessoal de tecnologia da informação e de segurança da informação, com atribuição de nota ou conceito, tendo como critério de avaliação o alcance das metas previstas.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A evidência apresentada, a Política de Segurança da Informação e Comunicação (POSIC), estabelece diretrizes e responsabilidades, mas não contempla a avaliação de desempenho individual. Não há documento normativo, registro, nota ou conceito de avaliação que comprove o alcance de metas para o pessoal de TI ou de Segurança da Informação. A suficiência da evidência é nula quanto ao objeto auditado. Existe a lacuna completa de instrumentos formais que descrevam o processo de avaliação de desempenho individual.
Item avaliado	Q2707 - a) há normativo que trata da avaliação de desempenho dos colaboradores e gestores
Resposta informada pelo auditado	Sim
Avaliação	O documento encaminhado trata exclusivamente da Política de Segurança da Informação e Comunicação, não possuindo previsão de normas para avaliação de desempenho de colaboradores e gestores da instituição. A evidência é insuficiente para sustentar a afirmação. Falta o normativo específico de gestão de pessoas voltado à avaliação de desempenho.
Item avaliado	Q2707 - d) a avaliação abrange o desempenho dos colaboradores da área de tecnologia da informação
Resposta informada pelo auditado	Sim
Avaliação	Não há evidência de que a organização realize a avaliação de desempenho para colaboradores da área de tecnologia da informação. A documentação fornecida é limitada à Política de Segurança da Informação e não cobre aspectos de gestão de RH. Existe a lacuna de evidências da aplicação prática dessa avaliação para a referida área.
Item avaliado	Q2707 - e) a avaliação abrange o desempenho dos colaboradores da área de segurança da informação



Resposta

informada pelo Sim

auditado

Avaliação

Não foi apresentada evidência que demonstre a existência de avaliação de desempenho para os colaboradores da área de segurança da informação. O material enviado restringe-se às diretrizes da política de segurança, não abrange processos de gestão de pessoas. Falta a comprovação de critérios e registros de avaliação aplicados a estes profissionais.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP



Questão 2801. Os processos de trabalho relativos às contratações de tecnologia da informação estão definidos.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2801 - e) o processo de trabalho para a gestão e fiscalização de contratos contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa
Resposta informada pelo auditado	Sim
Avaliação	A Portaria define papéis de gestores e fiscais, contudo, o processo de trabalho para gestão rotineira não está detalhado, limitando-se a procedimentos de aditivos. Falta especificação para acompanhamento contínuo da execução contratual.
Item avaliado	Q2801 - f) são disponibilizados artefatos padronizados para a gestão e fiscalização de contratos de TI, como modelos de plano de fiscalização, termos de recebimento, relatórios de acompanhamento, registros de ocorrências, avaliações de desempenho contratual ou documentos equivalentes
Resposta informada pelo auditado	Sim
Avaliação	Não foram disponibilizados modelos para os artefatos fundamentais de gestão contratual citados na norma, restando a padronização limitada a checklists de prorrogação e quadros demonstrativos mensais.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2802. A organização executa processo de planejamento anual das contratações.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2802 - A organização executa processo de planejamento anual das contratações.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A evidência normativa apresentada, a Portaria DETRAN SEI N.º 6645/2024, disciplina o fluxo de contratações individuais e a fase preparatória de processos específicos, mas não comprova a existência ou a execução de um processo de planejamento anual consolidado de contratações (PCA). Embora o instrumento cite a previsão no PCA como requisito para contratações isoladas, não há nos documentos apresentados evidência da elaboração, aprovação ou monitoramento do Plano de Contratações Anual enquanto instrumento de planejamento global da organização.
Item avaliado	Q2802 - b) os setores relevantes da organização participam da elaboração do PCA
Resposta informada pelo auditado	Sim
Avaliação	A norma evidencia a participação de setores e Câmaras Temáticas na instrução e no planejamento de contratações individuais e específicas. Contudo, não há elementos que demonstrem a participação colaborativa desses setores na elaboração do Plano de Contratações Anual enquanto instrumento de planejamento macro da entidade.
Item avaliado	Q2802 - d) o PCA fundamenta a proposta orçamentária da organização
Resposta informada pelo auditado	Sim
Avaliação	A Portaria estabelece o fluxo de verificação de disponibilidade orçamentária por meio da Assessoria de Planejamento e Orçamento (ASSPLAN) em processos de contratação individuais. Não existe evidência documental ou normativa que demonstre que o Plano de Contratações Anual (PCA) sirva como base de fundamentação para a elaboração da proposta orçamentária global da organização.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP



TRIBUNAL DE CONTAS DO ESTADO DO RIO DE JANEIRO
SECRETARIA-GERAL DE CONTROLE EXTERNO – SGE
SUBSECRETARIA DE CONTROLE DE POLÍTICAS DE CIDADANIA
COORDENADORIA DE AUDITORIA EM POLÍTICAS DE TECNOLOGIA DA INFORMAÇÃO

--

Questão 2803. A organização torna públicos os documentos relacionados com cada contratação de tecnologia da informação, contemplando as fases de planejamento, seleção do fornecedor e gestão contratual, excepcionados os casos de sigilo amparados pela legislação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2803 - A organização torna públicos os documentos relacionados com cada contratação de tecnologia da informação, contemplando as fases de planejamento, seleção do fornecedor e gestão contratual, excepcionados os casos de sigilo amparados pela legislação.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A organização demonstra a utilização do portal oficial para divulgação, porém a evidência é insuficiente para atestar a publicidade integral das fases de planejamento e seleção. O documento apresentado comprova apenas a existência de um empenho no repositório. Falta a comprovação documental do ciclo completo da contratação, especificamente ETP, TR e etapas de seleção.
Item avaliado	Q2803 - a) o Estudo Técnico Preliminar (ETP) das contratações é publicado no Portal Nacional de Compras Públicas (PNCP)
Resposta informada pelo auditado	Sim
Avaliação	A evidência apresentada restringe-se a uma nota de empenho. Não há registro ou documento que comprove a disponibilização do Estudo Técnico Preliminar no portal indicado. É necessária a apresentação do documento ou do link de acesso ao ETP.
Item avaliado	Q2803 - b) o Termo de Referência (TR) ou projeto básico das contratações é publicado no PNCP
Resposta informada pelo auditado	Sim
Avaliação	O documento exibido refere-se exclusivamente a dados orçamentários de empenho. A organização não comprovou a publicidade do Termo de Referência conforme exigido. Falta a demonstração da publicação do TR correspondente.
Item avaliado	Q2803 - c) o edital de credenciamento e de pré-qualificação, o aviso de contratação direta e o edital de licitação e respectivos anexos são publicados no PNCP
Resposta informada pelo auditado	Sim



Avaliação	A evidência anexada trata de uma nota de empenho e não contempla o aviso ou edital de contratação. O elemento de prova é insuficiente para demonstrar o cumprimento deste item. Falta a apresentação de documento relativo ao aviso ou edital publicado.		
Item avaliado	Q2803 - d) a ata de registro de preços, a ata de julgamento, contendo propostas e lances oferecidos (quando for o caso) são publicadas no PNCP		
Resposta informada pelo auditado	Sim		
Avaliação	A documentação apresentada não contém atas de registro de preços ou de julgamento. O comprovante limita-se à emissão de empenho, o que não atende à amplitude do requisito. Falta a apresentação de ata publicada no referido portal.		
Item avaliado	Q2803 - g) a análise realizada e justificativa dada para subsidiar a decisão de prorrogação contratual são publicadas no PNCP		
Resposta informada pelo auditado	Sim		
Avaliação	A evidência fornecida refere-se apenas ao empenho inicial, não havendo qualquer registro sobre prorrogação contratual. Para a conformidade, é necessário que a justificativa e análise de prorrogação estejam publicadas. Falta a documentação relativa a aditivos ou prorrogações.		

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP